

DLP Pattern & Sanitization Specification

What Aegis treats as sensitive, what the gateway does when it finds it, and how detection quality is proven.

DOCUMENT	OWNER	PHASE	CLASSIFICATION
AEGIS-SEC-DLP-001 v1.0 · 17 Aug 2026	Abdullah Zubair Cybersecurity Engineer	Phase 1 — Foundation Weeks 1–4	Internal / Confidential

1 Purpose & scope

Aegis is a centralized proxy between O&G endpoints and third-party LLMs. This document defines the sanitization contract that makes that proxy safe: the sensitive-content classes, the enforcement action for each class, the pattern pack that detects them, and the measurable quality bar the engine must clear before Phase 1 exit.

It governs every prompt, system message, and tool payload on the request path, and every document entering the RAG ingestion pipeline (see AEGIS-SEC-VDB-003). Authentication and model routing are out of scope and remain owned by the gateway pipeline.

2 Where sanitization happens

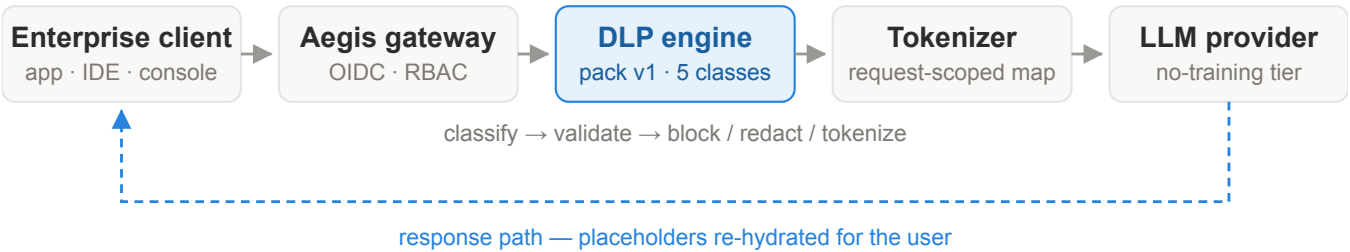


Fig. 1 — The engine is a synchronous in-line hop. If it errors or times out, the request fails closed.

3 Classification & action matrix

CLASS	CONTENT	ACTION	REVERSIBLE	ALERT
C1 Secrets	API keys, private keys, JWTs, DB connection strings, cloud credentials	Block	No	Security + manager
C2 Financial	Card numbers, IBAN, account and invoice pairs	Tokenize	On response	Aggregate only
C3 PII	Names with identifiers, national IDs, emails, phones, addresses	Tokenize	On response	Aggregate only
C4 Proprietary code	Internal repositories, large code spans, internal hostnames	Redact + warn	No	None
C5 Project confidential	Document refs, unreleased roadmap, client and partner names	Redact + warn	No	None

4 Detection layers

Regex alone over-blocks and under-detects. Four layers run in order, and a match is only acted on after validation.

LAYER	METHOD	CATCHES WHAT REGEX CANNOT
1. Format rules	Compiled regex over prompt, attachments, and tool arguments	—
2. Validators	Luhn for card numbers, mod-97 for IBAN, checksum for national IDs, Shannon entropy above 4.0 for random-looking secrets	Kills most false positives: order numbers, hashes, version strings
3. Local NER	On-premise model, no external calls	People, organisations, locations in free text
4. Lists & glossary	Internal domain deny-list, project code-name glossary, public-reference allow-list	Context-specific confidential terms

5 Tokenization contract

- Replace each match with a stable placeholder, for example `[[PII_EMAIL_7f3a]]`, so the model keeps coreference and the answer stays useful.
- Hold the mapping in a request-scoped, in-memory vault keyed by request ID, encrypted with the tokenization DEK; TTL equals the request lifetime.
- Re-hydrate on the response path only, for the originating session. Never persist plaintext mappings to logs, traces, or disk.

6 Pattern pack v1

```
# C1 secrets – block request, alert security
AWS_ACCESS_KEY      AKIA[0-9A-Z]{16}
GENERIC_API_KEY      (?i)(api[_-]?key|secret|token)\s*[:=]\s*['"]?[A-Za-z0-9\-\_]{20,}
PRIVATE_KEY_BLOCK    -----BEGIN (RSA |EC |OPENSSH )?PRIVATE KEY-----
JWT                  eyJ[A-Za-z0-9_-]{10,}\.[A-Za-z0-9_-]{10,}\.[A-Za-z0-9_-]{10,}
DB_CONN_STRING       (?i)(postgres|mysql|mongodb)(\+srv)?://[^\s:@]+:[^\s@]+@
# C2 / C3 identifiers – tokenize, validate before acting
PAN                  \b(?:\d[ -]*?){13,16}\b      + Luhn
IBAN                  \b[A-Z]{2}\d{2}[A-Z0-9]{11,30}\b    + mod-97
EMAIL                 \b[\w.+-]+@[^\w-]+\.[\w.]{2,}\b
PHONE_INTL            \+\d{1,3}[\s-]?[0-9]{6,12}
NATIONAL_ID           \b\d{5}-\d{7}-\d\b
# C4 / C5 proprietary – redact and warn the user
INTERNAL_HOST         (?i)\b[\w-]+\.[\w-]+(internal|corp|og-net)\b
DOC_REF               (?i)\b0&G-[A-Z]{3,10}-[A-Z]{3,6}-\d{4}-V\d+\b
CODE_SPAN_LARGE        heuristic: code span > 400 chars or > 25 lines
```

Shipped as signed, versioned config in Git (dlp-pack-v1.yaml) and hot-reloaded, so a bad pattern is rolled back without a gateway redeploy.

7 Acceptance criteria for Phase 1 exit

MEASURE	TARGET	EVIDENCE
Recall on C1 secrets	0.98 or better	Regression suite — QA
Overall false-positive rate	2% or lower	Labelled corpus, weekly report
Added latency, p95	Under 50 ms	Load test, Phase 3 gate
Behaviour on engine error	Fail closed, request blocked	Fault-injection test
Pattern rollback time	Under 5 min, no redeploy	Hot-reload drill

Bypass techniques — homoglyphs, base64, zero-width characters, and secrets split across turns — become permanent regression cases owned by the QA lead.

Open decision before build freeze: confirm with the Team Lead that hard-blocking C1 is acceptable to the business, and name the approver for tokenize-versus-block on C3 PII.

PREPARED BY Abdullah Zubair Cybersecurity Engineer ----- Signature / date	REVIEWED BY Arjun Pakhan Co-Leader, gateway pipeline ----- Signature / date	APPROVED BY Hrishikesh Reddy Team Lead ----- Signature / date
--	--	--